

ISG012-03 - Firewalls de Perímetro e Filtragem Avançada - Q de múlt escolha – Gabarito

Como obter maior aproveitamento deste objeto de aprendizagem:

1. Responder sem olhar o gabarito. Para isso, procurar pelas respostas nos slides da aula “ISG012-03 - Firewalls de Perímetro e Filtragem Avançada” (teoria e prática);
1. Após responder TODAS as questões, comparar com o gabarito;
2. Refazer os passos 1 e 2 novamente com todas as questões até obter 100% de acertos de uma só vez.

Importante: Embora seja baseado nos slides teóricos e nas atividades práticas, este questionário pode conter informações que não constam nesses documentos pois pode incluir algum nível detalhamento em relação a eles. Assim, considere as informações aqui contidas como parte complementar do conteúdo a ser estudado para as provas. Todo o material distribuído pelo professor poderá ser utilizado para a confecção das questões das provas.

Teoria (14 questões)

1. Qual é o objetivo principal desta aula sobre Firewalls de Perímetro e Filtragem Avançada?

- a) Ensinar configuração de switches Cisco apenas
- b) Desenvolver aplicações web seguras em Java
- c) Capacitar estudantes a compreender e implementar arquiteturas de segurança de perímetro com firewalls modernos
- d) Configurar exclusivamente antivírus de endpoint

Resposta correta: c

Comentário: O conteúdo programático visa capacitar os estudantes a compreenderem e implementarem arquiteturas de segurança de perímetro, diferenciando tipos de firewalls, projetando DMZ e configurando NAT com nftables.

2. Em qual posição topológica típica se localiza um firewall de perímetro?

- a) No centro da rede interna, entre departamentos
- b) Na borda da infraestrutura, entre a rede organizacional e a Internet
- c) Apenas dentro da DMZ de backend
- d) Somente em servidores de arquivos internos

Resposta correta: b

Comentário: Firewalls de perímetro são posicionados na borda (edge/border) da infraestrutura, constituindo a primeira linha de defesa entre a rede organizacional e a Internet.

3. O packet filtering firewall (1ª geração) opera em qual camada do modelo OSI?

- a) Camada 2 (Enlace)
- b) Camada 5 (Sessão)
- c) Camada 3 (Rede)
- d) Camada 7 (Aplicação)

Resposta correta: c

Comentário: O packet filtering firewall opera na camada 3 do modelo OSI, analisando cabeçalhos IP e portas TCP/UDP, sendo rápido mas limitado por não inspecionar o conteúdo.

4. Qual característica define corretamente a 1ª geração de firewalls (Packet Filter)?

- a) Realiza inspeção profunda de conteúdo na camada 7
- b) É stateful e mantém tabela de conexões ativas
- c) Identifica usuários através de integração com Active Directory
- d) É rápido, stateless, analisa cada pacote isoladamente e é vulnerável a spoofing

Resposta correta: d

Comentário: A 1ª geração é stateless, analisa pacotes individualmente sem contexto de conexão e é vulnerável a ataques de spoofing, diferentemente das gerações posteriores.

5. A DMZ (Zona Desmilitarizada) é definida como:

- a) Uma sub-rede intermediária que expõe serviços externos à Internet, isolando-os da rede interna corporativa
- b) A rede interna completa onde residem os ativos críticos
- c) Um tipo de firewall de aplicação específico para e-mail
- d) A zona de maior confiança da arquitetura de rede

Resposta correta: a

Comentário: A DMZ é uma sub-rede física ou lógica que hospeda serviços públicos (web, DNS, e-mail) e funciona como área intermediária de segurança entre a Internet e a rede interna.

6. Na arquitetura de firewall de perímetro com DMZ, qual é a função do firewall externo (perímetro)?

- a) Proteger a rede interna da DMZ com regras restritivas
- b) Filtrar tráfego entre Internet e DMZ, permitindo apenas portas específicas para servidores públicos
- c) Permitir acesso irrestrito da Internet para a rede interna
- d) Gerenciar apenas o tráfego de e-mail corporativo

Resposta correta: b

Comentário: O firewall de perímetro (externo) controla o tráfego entre a zona não confiável (Internet) e a zona controlada (DMZ), tipicamente permitindo apenas portas específicas como 80, 443, 25 e 53.

7. Segundo o princípio do menor privilégio no design de DMZ, servidores nessa zona devem:

- a) Ter acesso total à rede interna para facilitar a administração
- b) Ter todas as portas abertas para garantir disponibilidade
- c) Ter apenas as portas necessárias abertas e comunicação restrita com a rede interna
- d) Ser posicionados diretamente na rede interna sem isolamento

Resposta correta: c

Comentário: O design efetivo de DMZ exige que servidores públicos tenham apenas as portas estritamente necessárias abertas e comunicação mínima com a rede interna, protegendo ativos críticos.

8. Qual é a principal vantagem de um firewall stateful em relação a um stateless?

- a) É mais rápido e consome menos recursos de hardware
- b) Não analisa cabeçalhos IP para filtragem
- c) Opera exclusivamente com protocolos UDP
- d) Bloqueia ataques de spoofing e permite tráfego de retorno automático sem regras explícitas

Resposta correta: d

Comentário: O firewall stateful mantém uma tabela de estados (state table) que registra conexões ativas, permitindo identificar pacotes de sessões estabelecidas e bloquear spoofing, além de simplificar as regras.

9. A tabela de estados (state table) de um firewall stateful tipicamente contém:

- a) O 5-tuple (IP origem/destino, portas origem/destino, protocolo), estado TCP e timestamps
- b) Apenas o endereço MAC dos dispositivos
- c) Somente o nome de usuário de quem iniciou a conexão
- d) Apenas o tamanho total dos pacotes transmitidos

Resposta correta: a

Comentário: Cada entrada na state table contém o 5-tuple, o estado atual da conexão TCP (SYN_SENT, ESTABLISHED, TIME_WAIT), timestamps de última atividade e flags de controle.

10. Qual é a principal função do NAT (Network Address Translation) em firewalls de perímetro?

- a) Criptografar todo o tráfego entre rede interna e Internet
- b) Permitir que múltiplos hosts em redes privadas compartilhem endereços IP públicos e ocultem a topologia interna
- c) Aumentar a velocidade de conexão com a Internet
- d) Substituir a necessidade de firewalls na rede

Resposta correta: b

Comentário: O NAT permite que hosts em redes privadas (RFC 1918) compartilhem IPs públicos e proporciona segurança adicional ao ocultar a topologia interna da rede.

11. O Source NAT (SNAT) com masquerade é implementado em qual chain do nftables?

- a) PREROUTING
- b) INPUT
- c) POSTROUTING
- d) FORWARD

Resposta correta: c

Comentário: O SNAT é implementado na chain POSTROUTING, pois a alteração do endereço de origem deve ocorrer após a decisão de roteamento, antes do pacote sair pela interface externa.

12. O Destination NAT (DNAT) é implementado em qual chain do nftables?

- a) POSTROUTING
- b) OUTPUT
- c) FORWARD
- d) PREROUTING

Resposta correta: d

Comentário: O DNAT é aplicado na chain PREROUTING, antes da decisão de roteamento, para que o pacote seja corretamente redirecionado para a rede interna ou DMZ.

13. No fluxo de processamento do netfilter, qual é a ordem correta dos hooks para um pacote encaminhado entre interfaces?

- a) PREROUTING → Decisão de roteamento → FORWARD → POSTROUTING
- b) INPUT → FORWARD → OUTPUT → POSTROUTING
- c) PREROUTING → INPUT → FORWARD → OUTPUT
- d) POSTROUTING → FORWARD → PREROUTING → INPUT

Resposta correta: a

Comentário: Pacotes encaminhados passam por PREROUTING (onde DNAT é aplicado), decisão de roteamento, chain FORWARD e finalmente POSTROUTING (onde SNAT é aplicado) antes de sair.

14. Qual é a prática recomendada de hardening para a política padrão (default policy) de um firewall?

- a) ACCEPT all, DROP explicitamente o que não é necessário
- b) DROP all, ALLOW explicitamente apenas o tráfego necessário (whitelist)
- c) REJECT all sem nenhuma exceção
- d) ACCEPT all e logar apenas tráfego HTTP

Resposta correta: b

Comentário: A política padrão deve ser DROP para todas as chains, permitindo explicitamente apenas o tráfego necessário, minimizando a superfície de ataque.

Prática (6 questões)

15. Quantas VMs são necessárias para montar o ambiente da prática de firewall de perímetro no VirtualBox?

- a) 1 VM
- b) 2 VMs
- c) 3 VMs
- d) 4 VMs

Resposta correta: c

Comentário: O ambiente final utiliza 3 VMs: Firewall (2 interfaces), Servidor DMZ (1 interface) e Estação de Trabalho (1 interface).

16. Qual é o endereço IP atribuído à interface WAN (eth0/NAT) do firewall no ambiente VirtualBox?

- a) 192.168.56.1/24
- b) 192.168.56.10/24
- c) 172.16.0.1/24
- d) 10.0.2.15 (DHCP)

Resposta correta: d

Comentário: A interface eth0 (NAT VirtualBox) do firewall recebe IP via DHCP na rede 10.0.2.0/24, tipicamente 10.0.2.15, simulando o acesso à Internet.

17. Qual é o endereço IP configurado no Servidor DMZ na rede interna?

- a) 192.168.56.10/24
- b) 192.168.56.20/24
- c) 10.0.2.15/24
- d) 192.168.56.1/24

Resposta correta: a

Comentário: O Servidor DMZ é configurado com IP estático 192.168.56.10/24 na rede interna VirtualBox, com gateway 192.168.56.1.

18. Qual comando habilita temporariamente o IP forwarding no firewall Linux?

- a) `sudo sysctl -w net.ipv4.ip_forward=0`
- b) `sudo sysctl -w net.ipv4.ip_forward=1`
- c) `sudo nft enable forwarding`
- d) `sudo echo 1 > /etc/ip_forward`

Resposta correta: b

Comentário: O comando `sudo sysctl -w net.ipv4.ip_forward=1` ativa o encaminhamento de pacotes entre interfaces temporariamente; para persistir, edita-se `/etc/sysctl.conf`.

19. Na chain INPUT do script prático, qual serviço é permitido apenas pela interface interna (enp0s8)?

- a) HTTP na porta 80
- b) DNS na porta 53
- c) SSH na porta 22
- d) HTTPS na porta 443

Resposta correta: c

Comentário: A regra `nft add rule inet filter input iifname "enp0s8" tcp dport 22 ct state new accept` permite SSH apenas pela interface LAN, bloqueando acesso administrativo pela WAN.

20. Na regra de DNAT da prática, qual redirecionamento é configurado?

- a) Porta 80 da WAN para porta 8080 do servidor interno
- b) Porta 22 da WAN para porta 2222 do servidor interno
- c) Porta 443 da WAN para porta 80 do servidor interno
- d) Porta 8080 da WAN para porta 80 do servidor interno (192.168.56.10)

Resposta correta: d

Comentário: A regra `nft add rule ip nat prerouting iifname "enp0s3" tcp dport 8080 dnat to 192.168.56.10:80` redireciona a porta 8080 externa para a porta 80 do servidor web na DMZ.